

Vulnerability scanning

Vulnerability scanning, is the process of evaluating networks or IT assets for security vulnerabilities, flaws or weaknesses that external or internal threat actors can exploit. Vulnerability scanning is the first stage of the broader vulnerability management lifecycle.

It identifies security weaknesses — including missing patches, misconfigurations, open ports, outdated software versions, and known vulnerabilities (CVEs).

Reason	Explanation
Proactive defense	Find weaknesses before attackers do
Compliance	Required by frameworks like PCI DSS, HIPAA, ISO 27001, SOC 2
Attack surface reduction	Identifies unnecessary open ports/services to harden
Patch management	Flags missing security updates
Risk prioritization	Helps teams focus on critical issues first
Continuous monitoring	Security posture changes as systems evolve

Types of vulnerability scanner:

Network Scanner, Web Application Scanner, Host-Based Scanner

Tools:

Openvas, greenbone, wazuh, splunk, Nmap, Nikto webscanner, etc.

Installing nmap:

1. If you are installing nmap on kali linux then run the command **sudo apt install nmap**

```
(root@kali123)-[/home/kali123]  
# apt install nmap
```

As per my case, it's already installed so just upgrading is going on

```
# apt install nmap
Upgrading:
  ndiff  nmap  nmap-common  zenmap

Summary:
  Upgrading: 4, Installing: 0, Removing: 0, Not Upgrading: 2134
  Download size: 7,638 kB
  Space needed: 1,275 kB / 1,715 MB available

Continue? [Y/n] Y
Get:1 http://http.kali.org/kali kali-rolling/non-free amd64 nmap amd64 7.99+dfsg-1kali1 [1,987 kB]
Get:2 http://http.kali.org/kali kali-rolling/non-free amd64 ndiff all 7.99+dfsg-1kali1 [313 kB]
Get:3 http://http.kali.org/kali kali-rolling/non-free amd64 nmap-common all 7.99+dfsg-1kali1 [4,698 kB]
Get:4 http://http.kali.org/kali kali-rolling/non-free amd64 zenmap all 7.99+dfsg-1kali1 [640 kB]
Fetched 7,638 kB in 2s (3,931 kB/s)
Reading database ... 95%
```

2. Scanning the ports of my own virtual lab

```
(root@kali1123) - [ /home/kali1123 ]
# nmap 150.1.7.100
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-11 12:53 -0400
```

3. Report gives us the open ports. Port numbers along the state and service are stated

```
Nmap scan report for 150.1.7.100
Host is up (0.00059s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
MAC Address: 00:50:56:C0:00:01 (VMware)
```

NSE Scripts

1. For comprehensive service + version detection + default scripts use **nmap -sV -sC (x.x.x.x)**

```
(root@kali1123) - [ /home/kali1123 ]
# sudo nmap -sV -sC 150.1.7.100
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-11 13:08 -0400
Nmap scan report for 150.1.7.100
Host is up (0.00033s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds?
MAC Address: 00:50:56:C0:00:01 (VMware)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ nbstat: NetBIOS name: DESKTOP-R4NOV30, NetBIOS user: <unknown>, NetBIOS MAC: 00:50:56:c0:00:01 (VMware)
|_ clock-skew: -1s
|_ smb2-time:
|   date: 2026-06-11T17:08:21
|_ start_date: N/A
|_ smb2-security-mode:
|   3.1.1:
|_ Message signing enabled but not required
```

2. For HTTP enumeration use **nmap--script=http-enum x.x.x.x**

```
(root@kali123)-[/home/kali123]
# nmap --script=http-enum 150.1.7.100
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-11 13:20 -0400
Nmap scan report for 150.1.7.100
Host is up (0.00029s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
MAC Address: 00:50:56:C0:00:01 (VMware)
```

3. For SSH enumeration use **nmap--script=ssh2-enum-algos x.x.x.x**

```
(root@kali123)-[/home/kali123]
# nmap --script=ssh2-enum-algos 150.1.7.100
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-11 13:24 -0400
Nmap scan report for 150.1.7.100
Host is up (0.00035s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
MAC Address: 00:50:56:C0:00:01 (VMware)
```

4. For MySQL enumeration use **nmap--script=mysql-info x.x.x.x**

```
(root@kali123)-[/home/kali123]
# nmap --script=mysql-info 150.1.7.100
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-11 13:32 -0400
Nmap scan report for 150.1.7.100
Host is up (0.031s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
MAC Address: 00:50:56:C0:00:01 (VMware)
```

5. Vulnerability detection scripts use **nmap--script=vuln x.x.x.x**

```
(root@kali123)-[/home/kali123]
# nmap --script=vuln 150.1.7.100
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-11 13:35 -0400
Nmap scan report for 150.1.7.100
Host is up (0.00049s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
MAC Address: 00:50:56:C0:00:01 (VMware)

Host script results:
|_samba-vuln-cve-2012-1182: Could not negotiate a connection:SMB: Failed to receive bytes: ERROR
|_smb-vuln-ms10-054: false
|_smb-vuln-ms10-061: Could not negotiate a connection:SMB: Failed to receive bytes: ERROR
```

6. For aggressive scan use switch **-A** which enables: OS detection (**-O**), version detection (**-sV**), script scanning (**-sC**), traceroute use **sudo nmap -A x.x.x.x**

```
(root@kali123) - [/home/kali123]
# nmap -A 150.1.7.100
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-11 13:41 -0400
Nmap scan report for 150.1.7.100
Host is up (0.00042s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE        VERSION
135/tcp    open  msrpc          Microsoft Windows RPC
139/tcp    open  netbios-ssn    Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds?
MAC Address: 00:50:56:C0:00:01 (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Microsoft Windows 10|11|2019 (97%)
OS CPE: cpe:/o:microsoft:windows_10 cpe:/o:microsoft:windows_11 cpe:/o:microsoft:windows_server_2019
Aggressive OS guesses: Microsoft Windows 10 1803 (97%), Microsoft Windows 10 1903 - 22H2 (97%), Microsoft
Windows 10 22H2 (97%), Microsoft Windows 11 (94%), Microsoft Windows 10 1809 (92%), Microsoft Windows 10 1
909 (91%), Microsoft Windows 10 1909 - 2004 (91%), Microsoft Windows Server 2019 (91%), Microsoft Windows
10 20H2 (88%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ smb2-time:
|   date: 2026-06-11T17:42:13
|_  start_date: N/A
|_ nbstat: NetBIOS name: DESKTOP-R4NOV30, NetBIOS user: <unknown>, NetBIOS MAC: 00:50:56:c0:00:01 (VMware)
|_ clock-skew: -1s
|_ smb2-security-mode:

TRACEROUTE
HOP RTT      ADDRESS
1   0.42 ms  150.1.7.100
```

The CVE System

A CVE is a unique identification number assigned to a publicly known security flaw, enabling consistent tracking across various tools and databases. It helps security teams quickly reference and research the issue. For example, similar to a product recall number for a faulty car part, but applied to software vulnerabilities.

Common Vulnerabilities and Exposures (CVE) generally refers to the CVE list, a publicly disclosed catalog of information security vulnerabilities established and maintained by the MITRE Corporation . The CVE catalog is more like a dictionary than a CVE database. It provides one name and one description for each vulnerability or exposure. In doing so, it enables communication between disparate tools and databases and helps improve interoperability and security coverage.

Real-world CVEs with severity ratings

1. CVE-2023-36884 — Windows Search MSHTML HIGH (CVSS 8.3)

Field	Detail
Description	An RCE vulnerability in Windows Search via malicious Office documents. When a user opens a crafted file, Windows Search invokes the vulnerable MSHTML (Trident) engine, allowing remote code execution in the context of the user. Exploited by RomCom APT group.
Affected	Windows 10/11, Server 2022, Office 2019/2021/LTSC

Impact	Code execution via email/document vector (zero-click in some cases)
Discovery	Microsoft (actively exploited in the wild)
Patch	Microsoft August 2023 Patch Tuesday (KB5029263+)
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

2. CVE-2021-44228 — Log4Shell CRITICAL (CVSS 10.0)

Field	Detail
Description	A remote code execution vulnerability in Apache Log4j 2's JNDI lookup feature. Attackers inject a crafted string (<code>\${jndi:ldap://...}</code>) into any log field, causing the server to load remote class files and execute arbitrary code.
Affected	Log4j 2.0 - 2.14.1
Impact	RCE on millions of Java applications worldwide
Discovery	Chen Zhaojun (Alibaba Cloud Security)
Patch	Upgrade to Log4j 2.17.0+ or 2.12.3+ (Java 7)
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

3. CVE-2024-21626 — runc Container Escape HIGH (CVSS 8.6)

Field	Detail
Description	A remote code execution vulnerability in Apache Log4j 2's JNDI lookup feature. Attackers inject a crafted string (<code>\${jndi:ldap://...}</code>) into any log field, causing the server to load remote class files and execute arbitrary code.
Affected	Log4j 2.0 - 2.14.1
Impact	RCE on millions of Java applications worldwide
Discovery	Chen Zhaojun (Alibaba Cloud Security)
Patch	Upgrade to Log4j 2.17.0+ or 2.12.3+ (Java 7)
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

4. CVE-2023-44487 — HTTP/2 Rapid Reset HIGH (CVSS 7.5)

Field	Detail
Description	A DDoS attack vector in the HTTP/2 protocol. Attackers rapidly open and reset streams, exhausting server resources without completing handshakes. Affected every major HTTP/2 implementation (nginx, Apache, Node.js, Go, etc.).

Affected	Nearly all HTTP/2 implementations globally
Impact	Massive amplification DDoS, server resource exhaustion
Discovery	Google & AWS (August 2023)
Patch	Rate limiting on stream resets, protocol-level fixes
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

CVSS scoring system

CVSS (Common Vulnerability Scoring System) is an open standard for rating vulnerability severity. The latest version, **CVSS v4.0**, was officially released by the Forum of Incident Response and Security Teams (FIRST) on November 1, 2023.

Reading a CVSS Vector

Example: **CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H**

Reading left to right:

AV:N = Attack via Network (no physical/adjacent access needed)

AC:L = Low complexity (no special conditions)

PR:N = No privileges required

UI:N = No user interaction

S:C = Scope changed (attack affects component beyond the vulnerable one)

C:H/I:H/A:H = High impact on Confidentiality, Integrity, and Availability

This is the maximal score — 10.0 (Critical)

Template: Vulnerability Report Template

1. Report Information

Report Title:

Prepared By:

Date:

System / Application Name:

IP Address / URL:

Environment: (Production / Test / Lab)

2. Vulnerability Summary

Vulnerability Name:

Severity: (Critical / High / Medium / Low)

Category: (e.g., SQL Injection, XSS, Misconfiguration)

CVSS Score (if known):

3. Description

Explain the vulnerability in simple terms:

- What is the issue?
- Where is it found?
- How does it affect the system?

4. Affected Components

- Application modules / pages / services affected
- Example: Login page, API endpoint /api/login

5. Technical Details

Steps to reproduce:

1. Step one
2. Step two
3. Step three

Proof of Concept :

- Payload used (if any)
- Screenshots (if required)

6. Impact

- Data leakage
- Unauthorized access
- System compromise
- Privilege escalation

7. Risk Rating

Business impact:

Likelihood:

Overall risk:

8. Recommendation / Fix

- Patch/update software
- Input validation
- Access control improvements
- Best practices to prevent it

9. References

- OWASP link (if applicable)
- CVE details
- Security documentation

10. Screenshots (Optional)

- Before exploit
- After exploit
- Error messages / logs